

Fundamentals of Information Systems Security

Case Study: GDPR Fines and Enforcement

Real Penalties for Non-Compliance with Data Protection Regulations

Executive Summary

The General Data Protection Regulation (GDPR), which came into effect on May 25, 2018, represents one of the most significant data protection frameworks in the world[reference:170]. With the authority to impose fines of up to €20 million or 4% of global annual turnover (whichever is higher), the GDPR has fundamentally changed how organizations handle personal data. Since its implementation, supervisory authorities across Europe have issued billions of euros in fines, targeting organizations ranging from major technology companies to small businesses[reference:171][reference:172]. This case study examines notable GDPR fines, enforcement trends, and the critical compliance lessons for organizations.

Overview of GDPR Fines

Total Fines Imposed

From January 28, 2024, to January 27, 2025, a total of €1.2 billion (approximately USD 1.26 billion) in GDPR fines were imposed across surveyed countries[reference:173]. While this represents a 33% decrease from the previous year's €1.78 billion, it still demonstrates the significant financial risk of non-compliance[reference:174].

Top Fining Countries

Ireland dominates GDPR enforcement, with the Irish Data Protection Commission (DPC) issuing a cumulative total of €3.5 billion in fines since the regulation's implementation[reference:175]. Eight of the top ten largest GDPR fines ever imposed have been issued by the Irish DPC[reference:176].

Country	Total Fines (Cumulative)	Notable Cases
Ireland	€3.5 billion	Meta (€1.2B), LinkedIn (€310M)
Luxembourg	€746.38 million	Amazon (€746M)
Netherlands	Various	Uber (€290M)

Table 1: Top Countries by GDPR Fines[reference:177]

Major GDPR Fines: The Top Cases

1. Meta (2023) - €1.2 Billion

The largest GDPR fine ever imposed was issued against Meta Platforms Ireland Limited by the Irish Data Protection Commission in 2023[reference:178][reference:179]. The €1.2 billion fine related to:

- Transfers of personal data from the EU to the United States
- Failure to implement adequate safeguards for data transfers

- Violations of Chapter V of the GDPR (transfers of personal data to third countries)

This fine remains the record for the highest GDPR penalty ever imposed[reference:180].

2. LinkedIn (2024) - €310 Million

In October 2024, the Irish Data Protection Commission imposed a €310 million fine on LinkedIn[reference:181][reference:182]. The fine was related to:

- Behavioral advertising practices
- Insufficient legal basis for processing personal data
- Inadequate transparency regarding data processing activities

3. Meta (2024) - €251 Million

In December 2024, Meta received an additional €251 million fine from the Irish DPC[reference:183][reference:184]. This fine addressed:

- Data breach notification failures
- Insufficient security measures
- Violations of GDPR Article 33 (notification of a personal data breach to the supervisory authority)

4. Uber (2024) - €290 Million

In August 2024, the Dutch Data Protection Authority issued a €290 million fine against a well-known ride-hailing app[reference:185][reference:186]. The fine was related to:

- Transfers of personal data to a third country (the United States)
- Failure to implement appropriate safeguards for international data transfers

5. Amazon (2021) - €746 Million

Luxembourg's data protection authority imposed a €746 million fine on Amazon[reference:187]. The fine was related to:

- Processing of personal data for advertising purposes
- Lack of proper legal basis for data processing
- Insufficient transparency with users

Notable Fines in Other Sectors

While big technology companies remain the primary targets, supervisory authorities are increasingly issuing significant fines across various industries[reference:188].

Financial Services

The Spanish Data Protection Authority (AEPD) issued fines totaling €6.2 million against a large bank for multiple GDPR breaches, including[reference:189]:

- Inadequate security measures
- Failure to properly notify data subjects
- Insufficient data protection by design and default

In Poland, the Personal Data Protection Office (PUODO) fined several international banks for failing to notify customers of data breaches[reference:190].

Energy Sector

The Italian Data Protection Authority imposed a €5 million fine on a utility provider for[reference:191]:

- Using outdated and inaccurate customer data
- Failure to keep personal data accurate and up to date
- Violations of GDPR Article 5 (data accuracy principle)

Healthcare and Other Sectors

- **Finland (2025):** €950,000 fine against Sambla Group for inadequate restrictions preventing third parties from accessing loan application data[reference:192]
- **Estonia (2025):** €3 million fine against Allium UPI for insufficient security measures leading to a data breach[reference:193]
- **Austria (2024):** €1.5 million fine for unlawful operation of a video surveillance system[reference:194]

Enforcement Trends

Data Breach Notifications

The number of data breach notifications remains significant[reference:195]:

- Average of 363 notifications per day (January 2024 - January 2025)[reference:196]
- Increase from 335 notifications per day in the previous period[reference:197]
- The Netherlands, Germany, and Poland lead in breach notifications[reference:198]

Sectoral Diversification

While big tech companies remain primary targets, there is a growing trend of fines against organizations in finance, energy, healthcare, and other sectors[reference:199]. This indicates that supervisory authorities are increasingly confident in their enforcement capabilities[reference:200].

Personal Liability for Management

A notable trend is the potential for personal liability among company directors and management bodies[reference:201]. The Dutch Data Protection Authority announced an investigation into whether it could hold the directors of Clearview AI personally liable for GDPR breaches[reference:202]. This represents a significant shift toward greater accountability at the management level[reference:203].

Common Violations Leading to Fines

Analysis of GDPR enforcement actions reveals common categories of violations:

Violation Category	Examples
Insufficient Legal Basis	Processing personal data without proper consent or legitimate interest
International Data Transfers	Transferring data to countries without adequate protection
Inadequate Security Measures	Failure to implement appropriate technical and organizational measures
Data Breach Notification	Failure to notify supervisory authorities within 72 hours
Transparency Failures	Inadequate privacy notices and information for data subjects
Data Accuracy	Failure to keep personal data accurate and up to date
Data Protection by Design	Failure to implement privacy protections in system design
Non-Compliance with Data Subject Rights	Failure to respond to access, deletion, or rectification requests

Table 2: Common GDPR Violations

Lessons Learned

Lesson 1: Compliance Is Not Optional

The scale and frequency of GDPR fines demonstrate that organizations cannot afford to treat data protection as optional. The total fines imposed—over €1.2 billion in a single year—represent a significant financial risk.

Lesson 2: All Sectors Are at Risk

While technology companies face the largest fines, enforcement is expanding across all sectors[reference:204]. Financial institutions, energy companies, healthcare providers, and even small businesses must comply.

Lesson 3: International Data Transfers Require Careful Attention

Several of the largest fines (Meta €1.2B, Uber €290M) related to transfers of personal data to third countries[reference:205][reference:206]. Organizations must ensure adequate safeguards for international data transfers.

Lesson 4: Security Measures Must Be Robust

Fines for inadequate security measures are common and increasing[reference:207]. Organizations must implement appropriate technical and organizational measures to protect personal data.

Lesson 5: Data Breach Notification Is Critical

Failure to notify supervisory authorities within 72 hours can result in significant penalties. Organizations must have incident response procedures in place.

Lesson 6: Leadership Is Accountable

The trend toward personal liability for directors and management bodies[reference:208] means that compliance is not just an IT issue—it is a governance issue that requires executive attention.

Discussion Questions

1. Why has Ireland issued such a high proportion of GDPR fines?
2. What are the implications of the trend toward personal liability for directors?
3. How should organizations balance the cost of compliance against the risk of fines?
4. What responsibilities do technology companies have in protecting user data?
5. How does the GDPR differ from data protection regulations in other jurisdictions (e.g., CCPA in California)?

References

- DLA Piper. (2025). GDPR Fines and Data Breach Survey January 2025.
- GDPR Enforcement Tracker. (2026). Statistics.
- GDPR Buzz. (2025). GDPR Fines and Data Breach Survey 2025.
- RTÉ. (2026). Ireland retains top spot in data enforcement.
- Yahoo Finance. (2026). EU issued over €1.2bn in GDPR fines in 2025.